

ID	Tipo de Ameaça	Card	Componente/Fluxo	Descrição Detalhada	Impacto	Nível de Risco	Mitigação
T01	Divulgação de Dados (Data Disclosure)	DD5 - Superexposição de Dados Pessoais (Overexposure of Personal Data)	Integração de Saída com API WhatsApp (UC1, UC12)	O envio massivo e automático de editais e convites de feiras via API do WhatsApp exige o compartilhamento de contatos, nomes e detalhes do evento com um serviço de terceiros (Meta/WhatsApp).	Exposição do dado com mais serviços externos que o estritamente necessário, podendo levar ao uso imprevisto por plataformas terceiras.	Médio	Minimizar os dados inseridos nas requisições automáticas e garantir que as partes envolvidas tenham reais necessidades e acordos de privacidade estritos (Termos da API).
T02	Identificação (Identifying)	I5 - Conjunto de Dados Identificável (Identifiable Dataset)	Visualização de Cadastro Completo (UC03) e Armazenamento em Banco de Dados	A plataforma centraliza um dossiê unificado que agrupa e exhibe informações altamente identificáveis e sensíveis dos artesãos, incluindo números diretos como CPF, RG e imagens de comprovante de residência.	Um eventual vazamento interno ou externo amplifica severamente os danos ao titular, abrindo portas e viabilizando o roubo direto de identidades.	Alto	Implementar de forma rigorosa o RNFO4, limitando visualmente esses dados de identificação apenas para o papel autenticado de gestores da plataforma, além de adicionar criptografia aos dados em repouso.
T03	Não Conformidade (Non-Compliance)	Nc1 - Não Conformidade do Processamento com as Regulamentações Aplicáveis (Non-Compliance of Processing with Applicable Regulations)	Sincronização de Inscrições (UC06) e Consistência de Domínios (RNF01)	O sistema espelha passivamente a tabela da EMPREL para manter consistência, a qual inclui o processamento de categorias que exigem cuidado especial perante a lei, como autodeclarações de raça e opções de gênero.	Falta de adesão aos ritos da legislação de proteção (ex: LGPD) pode resultar em severas multas institucionais e alto dano de reputação para a Prefeitura.	Alto	Realizar uma validação prévia em colaboração com a equipe da EMPREL acerca do consentimento legal e promover um Relatório de Impacto à Proteção de Dados antes do lançamento em produção.
T04	Desconhecimento e Inintervenabilidade (Unawareness and Unintervenability)	U1 - Transparência Insuficiente (Insufficient Transparency)	Origem e Captura de Inscrições via Formulário Externo (Regra RN02)	Os artesãos preenchem seus dados exclusivamente na ponta externa (formulários EMPREL), que então sincroniza e espelha os registros no Backoffice restrito do PRODARTE.	Os titulares podem desconhecer o destino, os métodos de triagem ou a extensão do processamento dos seus dados ao transitar entre essas duas arquiteturas distintas.	Médio	Certificar-se de que o ponto de captação primário da EMPREL deixe claro em um Termo de Privacidade, em linguagem acessível e legível, de que os dados serão consumidos pela plataforma de curadoria PRODARTE.
T05	Desconhecimento e Inintervenabilidade (Unawareness and Unintervenability)	U5 - Retificação ou Apagamento Insuficiente (Insufficient Rectification or Erasure)	Backoffice Centralizado vs Usuário Passivo	Historicamente o PRODARTE tem como dor tratar documentos engessados sem edição própria pelo artesão ("papel em uma caixa"). Apesar da intenção, os Casos de Uso descritos são restritos e centrados somente no perfil do Gestor e sua operação manual.	Direitos legais diretos são prejudicados se o titular depender estritamente de intervenções e ligações manuais ou não conseguir exigir por conta própria que o sistema apague seus históricos no ambiente da prefeitura.	Médio	Incorporar um fluxo sistêmico claro de atendimento, ou habilitar autonomia (mesmo que na interface conectada da EMPREL), para que o artesão invoque requisições de correção e apagamento automáticos de seu dossiê.
T06	Divulgação de Dados (Data Disclosure)	DD4 - Retenção Desnecessária de Dados (Unnecessary Data Retention)	Histórico de Feiras (RF1), Critérios de Rodizio e Armazenamento (RN10)	O sistema retém continuamente dados de inatividade e vínculos e resultados completos de curadoria de participantes de anos anteriores. A especificação não cita e não aplica expurgo temporal em sua arquitetura de banco de dados.	Armazenar dados permanentemente e por longos prazos sem necessidade atual afeta negativamente as providências de minimização e infla radicalmente o raio de destruição em cenários de data breach.	Baixo	Adotar uma política automática e configurável sobre o Ciclo de Vida do Dado, removendo de forma programada portfólios visuais, inativos e logs antigos de candidatos após um determinado marco de tempo (ex: 2 a 5 anos).
T07	Vinculação (Linking)	L5 - Perfilamento de Usuários (Profiling Users)	Histórico de Participações (RF1) e Critério de Rodizio (RN10)	O sistema exige o registro de todo o histórico de feiras do artesão e calcula seu tempo de inatividade para gerar a fila do rodizio. O LINDDUN adverte que analisar dados em busca de padrões permite o perfilamento dos usuários.	O cruzamento contínuo de frequência de trabalho constrói um perfil comportamental e econômico profundo do artesão, que pode ser inferido indevidamente.	Baixo	Restringir o uso dos dados de inatividade estritamente ao algoritmo interno de rodizio, bloqueando a exportação desses perfis de frequência para outros órgãos ou propósitos não relacionados à feira.
T08	Divulgação de Dados (Data Disclosure)	DD1 - Coleta de Dados Excessivamente Sensíveis (Excessively Sensitive Data Collected)	Consistência de Domínios (RNF01) e Integridade de Domínios (RN13)	O banco de dados do PRODARTE espelha campos do formulário da EMPREL, importando obrigatoriamente dados como autodeclaração de raça e gênero. O LINDDUN alerta para sistemas que adquirem dados mais sensíveis do que o estritamente necessário para sua funcionalidade.	O vazamento ou uso incorreto de dados de raça e gênero (considerados dados pessoais sensíveis pela LGPD) aumenta severamente as consequências para os indivíduos e as sanções legais.	Alto	Avaliar tecnicamente se os dados de raça e gênero são vitais para a operação do rodizio. Caso não sejam, implementar uma regra de mascaramento (data masking) ou exclusão desses campos específicos durante a sincronização (UC06).
T09	Não Repúdio (Non-Repudiation)	Nr4 - Não Repúdio de Armazenamento (Non-Repudiation of Storage)	Registro de Auditoria (RN11) e Obrigatoriedade de Justificativa (RN04)	O sistema obriga que toda comunicação via WhatsApp seja salva no histórico e que toda rejeição tenha uma justificativa textual salva. Isso cria um armazenamento em que os usuários (gestores) não podem negar suas afirmações e decisões passadas.	Embora o registro de auditoria seja bom para a gestão, a permanência infinita de conversas e apontamentos pode retirar o direito de negação plausível de gestores e artesãos em caso de disputas legais.	Médio	Assegurar que os logs de mensagens e justificativas tenham controle de acesso severo e implementar regras de expurgo programado para o histórico de comunicações após o fim da vigência dos editais.
T10	Deteção (Detecting)	D3 - Eventos Detectáveis (Detectable Events)	Notificação Automática (RF10) e UC12	Quando um gestor aloca o artesão (evento interno), o sistema dispara automaticamente uma notificação para o WhatsApp do usuário (efeito colateral). Efeitos colaterais disparados por eventos da aplicação permitem a detecção de transmissões.	Um observador externo monitorando o tráfego de rede ou o dispositivo do usuário pode inferir que a seleção de editais da prefeitura acabou de ocorrer, mesmo sem acessar o sistema interno.	Baixo	Garantir que as comunicações da API do WhatsApp transitem exclusivamente por túneis criptografados (HTTPS/TLS) e omitir detalhes altamente restritos do corpo da mensagem de notificação (enviando apenas o essencial).
T11	Não Conformidade (Non-Compliance)	Nc4 - Segurança Insuficiente no Processamento (Insufficient Security of Processing)	Segurança no Upload (RNF03) e Acesso a Dados (RNF04)	O sistema permite upload manual de arquivos que representam dados sensíveis (comprovantes, RCs). Medidas de segurança insuficientes nesse manuseio ferem diretrizes de proteção.	Caso os "buckets" (servidores de armazenamento) de arquivos não sejam corretamente isolados na infraestrutura da EMPREL, dados em PDF/JPG ficam expostos a ataques de injeção ou raspagem (scraping).	Alto	Associar a restrição de extensões (PDF, JPG) do RNF03 ao uso de antivírus nativo no upload e garantir que os contêineres de armazenamento em nuvem não possuam acesso público sob nenhuma hipótese.